

INTRODUCTION AU TEST D'INTRUSION

Guide du TP 5

TP 5 · Analyser un test web

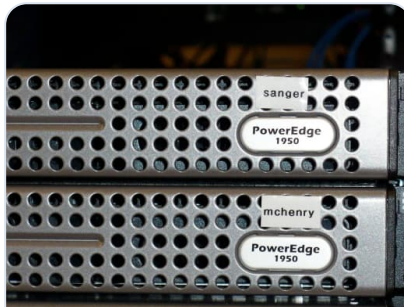


MATÉRIEL QUE TU CROISES DANS CE LABORATOIRE



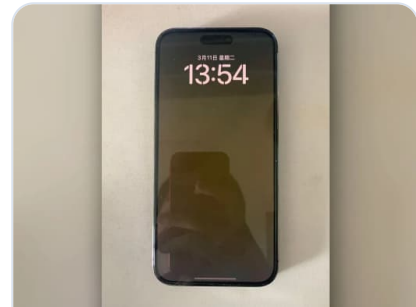
Ordinateur portable

L'ordinateur que l'on emporte partout



Serveur

Fournit fichiers, messagerie ou site web aux autres



Smartphone

Messages, photos, argent mobile et codes

Photos issues de Wikimedia Commons : Ordinateur portable, Ahunt, CC0 · Serveur, Florence Devouard, CC BY-SA 4.0 · Smartphone, 茅野ふたば, CC BY-SA 4.0.

À RETENIR

- ◆ Cadre et limites : tu analyses uniquement des fichiers fournis et fictifs.
- ◆ Ne teste jamais un système réel sans autorisation écrite.
- ◆ Tous les horodatages du proxy sont en UTC et se terminent par Z : ne les convertis pas en heure locale.

1 Lire le proxy sans te perdre

Le fichier JSONL contient une ligne JSON par événement du proxy.

Commence par filtrer `path`, `method`, `status` et `resourceType`.

Les lignes `static`, les 304 et les redirections servent surtout de bruit.

Pour compter une ressource métier, garde les chemins fonctionnels et retire la query string.

2 Statuts des notes

- ◆ **Confirmé** : la preuve minimale est visible dans les fichiers, avec un comportement défendable et reproductible sur dossier.
- ◆ **Hypothèse** : un indice existe, mais il manque une preuve d'acceptation, d'effet ou de lecture.
- ◆ **Réfuté** : la ligne de preuve attendue montre au contraire que le contrôle tient.

Un téléversement refusé n'est donc pas un constat : il faut une preuve d'acceptation ou de restitution.
Un 403 ou un 404 cohérent sur un identifiant manipulé va dans « réfuté » ou « rejet correct », pas dans « confirmé ».

3 Visionneuse du site

Dans la visionneuse, cherche d'abord un chemin comme `/auth/login`, puis un `resourceType`, puis un `status`.
Pour une question sur l'heure, copie exactement `HH:MM:SS` depuis l'horodatage UTC.
Pour une question sur un chemin, réponds avec `path` seulement, sans la query string.

4 Exemple Bash sur des données inventées

BASH

```
cat > guide-proxy-exemple.jsonl <<'EOF'
{"timestamp":"2026-06-10T08:10:00Z","method":"POST","path":"/auth/login","status":401,"resourceType":"auth"}
{"timestamp":"2026-06-10T08:10:10Z","method":"POST","path":"/auth/login","status":302,"resourceType":"auth"}
{"timestamp":"2026-06-10T08:11:00Z","method":"GET","path":"/api/contrats/view","status":200,"resourceType":"dossier"}
EOF
grep '"method":"POST"' guide-proxy-exemple.jsonl | grep '"path":"/auth/login"' | wc -l
```

BASH

```
cat > guide-doc-exemple.jsonl <<'EOF'
{"timestamp":"2026-06-10T08:14:00Z","path":"/api/rapports/telecharger","status":200,"resourceType":"document","responseBytes":4200}
{"timestamp":"2026-06-10T08:14:10Z","path":"/api/rapports/telecharger","status":200,"resourceType":"document","responseBytes":8300}
{"timestamp":"2026-06-10T08:14:20Z","path":"/api/contrats/view","status":200,"resourceType":"dossier","responseBytes":900}
EOF
grep '"resourceType":"document"' guide-doc-exemple.jsonl | grep '"status":200' | grep -o '"responseBytes":[0-9]*' | cut -d: -f2 | sort -n | tail -n 1
```

Commande longue, coupée par la mise en page : copie-la en une seule ligne ou utilise la version texte indiquée en fin de document.

5 Exemple PowerShell 5.1 sur des données inventées

POWERSHELL

```
@(
    '{"timestamp":"2026-06-10T08:20:00Z","status":"confirmé","noteId":"N01"}',
    '{"timestamp":"2026-06-10T08:21:00Z","status":"hypothèse","noteId":"N02"}',
    '{"timestamp":"2026-06-10T08:22:00Z","status":"confirmé","noteId":"N03"}'
) | Set-Content -Encoding UTF8 guide-notes-exemple.jsonl
$confirmed = Get-Content -Encoding UTF8 guide-notes-exemple.jsonl | ForEach-Object { $_ | ConvertFrom-Json } | Where-Object { $_.status -eq 'confirmé' }
$confirmed.Count
```

Commande longue, coupée par la mise en page : copie-la en une seule ligne ou utilise la version texte indiquée en fin de document.

POWERSHELL

```
@(
  '2026-06-10T08:24:00Z N41 Statut=hypothèse Preuve=aucune_acceptation',
  '2026-06-10T08:25:00Z N42 Statut=réfuté Preuve=403_cohérent'
) | Set-Content -Encoding UTF8 guide-statut-exemple.txt
Get-Content -Encoding UTF8 guide-statut-exemple.txt | Select-String 'hypothèse' | ForEach-Object { $_.Line.Split(' ')[1] }
```

6 Repérer un vrai défaut de contrôle d'accès

Pour un contrôle horizontal cassé, cherche une ligne où `manipulatedIdentifiant` vaut `true`, où `actorAccount` et `resourceOwner` diffèrent, et où la réponse reste `200` ou un autre succès. Si le serveur renvoie `403` ou `404` avec ces mêmes conditions, la tentative est rejetée correctement.

7 Repérer une faiblesse de session

Une faiblesse de session ne se limite pas à un mot de passe faible. Le mémo classe aussi ici la fixation de session, la rotation absente et le logout incomplet. Sur dossier, compare les cookies et les `set-cookie` avant et après la connexion réussie. Si l'identifiant de session ne change pas, la note reste défendable sans avoir besoin d'un test actif.

8 Choisir une formulation défendable

Une formulation défendable décrit le fait, sa preuve et sa limite. Évite les phrases absolues du type « le portail est totalement compromis » si le dossier ne le prouve pas. Préfère une phrase factuelle, précise et proportionnée au comportement observé.

9 À retenir

- ◆ Ne convertis pas le `Z` du proxy en heure locale.
- ◆ Un upload refusé reste une hypothèse, pas un constat.
- ◆ Une réponse 200 sur l'objet d'un autre compte oriente vers la catégorie Broken Access Control du mémo.
- ◆ Une session non régénérée après login oriente vers la catégorie d'authentification du mémo.



Pingo veille sur ta progression

Retourne au laboratoire pour valider tes réponses. Bloqué ? Ouvre d'abord l'indice de la tâche, la correction vient ensuite. Pour copier les commandes sans coupure de ligne, ouvre la [version texte](#).